

Sorted (Auriq Wealth): internal security test report, 2026-09

Product: Sorted, by Auriq (the AI wealth dashboard, "ai-wealth-dashboard") **Company:** AURIQ LTD **Report id:** AURIQ-SEC-RPT-2026-09-DRAFT **Version:** DRAFT v0.1, status as of 2026-09-23 **Classification:** Confidential, prepared for Finexer **Author:** AURIQ LTD, Information Security Manager: Kevin Maingi

Status of this document. This is a draft. Work packages 7b and 8 (dynamic mobile testing), work package 12 (cross-model review) and a production retest have not run. This report will be regenerated as `v1.0` once that work completes: after board item A110 (trusted-proxy hop handling) lands, the fix branch is released to production, a retest confirms each of the four High findings below, and WP12's cross-model review signs the coverage matrix and findings. Nothing in this document should be read as a final statement of Sorted's security posture; it is the internal precursor described in `docs/security/PENTEST-METHODOLOGY.md` section 11, not that final statement.

1. Summary

AURIQ LTD performed an internal security assessment of the recorded scope and builds, mapped to selected OWASP ASVS 5.0.0, WSTG 4.2, API Security Top 10:2023, MASVS/MASTG 2.0.0, OAuth, MCP, and LLM security guidance. The report records executed tests, limitations, blockers, findings, severity, and retest status. This was internal testing and was not an independent third-party or CREST engagement.

That is the mandatory reporting statement from `docs/security/PENTEST-METHODOLOGY.md` section 11, reproduced verbatim. Section 11 also states that the assessment is complete, and that statement final, only once WP12's independent review has signed the coverage matrix and findings; that has not happened yet, which is why this document is a draft, not the final report.

Headline. No Critical findings. Four High findings (A82, A83, A84, A91), all fixed on the `main` branch with regression tests, merged 2026-09-22. None of the four is deployed to production yet: production's `release` branch is still at commit `dcf00951` (tag `release-20260921-2020`), which predates all four fix commits. No production retest has run for any of them; retest status for every finding in this report is "Pending". The correct status wording throughout is "fixed on main, production release and retest pending", never "remediated" or "closed". Production release is itself gated on board item A110 (trusted-proxy hop handling for the related A92 rate-limit fix), in progress as of this report's date. Every Medium, Low and Informational finding raised by this round, plus one related residual follow-up (A106), is tracked individually in section 5. The MCP connector is disabled in production today (`MCP_CONNECTOR_ENABLED` unset, board item A17), confirmed live 2026-09-23 by an anonymous `initialize` request returning 401 with no `WWW-Authenticate` challenge on both the Vercel-fronted path and the direct Railway host, while UAT advertises the challenge; A91, the MCP prompt-injection finding, is therefore not exploitable in production today, whatever its state on `main`. Enabling the connector in production is separately gated on Finexer's written design sign-off (board item F1), which remains open.

Coverage is 10 of 12 planned work packages executed (WP7b, Android dynamic device testing, and WP8, iOS dynamic testing, have not run). WP12, the cross-model review where a Codex session checks every Claude-run package and a Claude session checks every Codex-run package, has not started, so every severity in this report is a single-reviewer, provisional judgement with the Information Security Manager's (Kevin Maingi's) sign-off, dated 2026-09-21, standing in for that cross-review until it happens.

2. Scope, environments and rules of engagement

What was tested. The web shell (Vercel), the REST API (Railway), the OAuth 2.1 authorisation server, the MCP connector, the Android app shell (static analysis only), and the Finexer, TrueLayer, Stripe and OpenRouter integration boundaries. Full surface definitions are in `docs/security/pentest-scope-2026-09.md`.

Hosts.

Host	Role
<code>https://wealth.auriq ltd.co.uk</code>	Production. The environment-of-record for almost every case in this round, per the rules-of-engagement record's third amendment (2026-09-20): production is the default environment once test identities are allow-listed there, not merely a fallback.

Host	Role
https://uat.wealth.auriqltd.co.uk	UAT. Retained as the only environment for OAuth (<code>OAuth-02</code> through <code>OAuth-10</code>) and MCP (<code>MCP-02</code> through <code>MCP-11</code>) cases, because <code>MCP_CONNECTOR_ENABLED</code> is off in production, so <code>backend/app/main.py</code> never registers those routers there; there is nothing on production for those specific cases to reach.

Builds. Each run's own manifest records the repository commit and deployment id under test at the time; see the per-work-package rows in section 4. No case in this round ran against a build later modified to pass a test it would otherwise have failed.

Test identities. Three pseudonymous identities only: PT-A (primary test user, controlled account and transaction data, a Finexer bank connection), PT-B (a second, isolated test user, used for cross-tenant checks), and PT-C (a disposable identity created by Kevin directly on production, used once for account-deletion testing then deleted). The real address behind each pseudonym lives only in a private, gitignored file (`.pentest-evidence/<run-id>/roe.env`), never in this report, the board, or any committed file. No real email address, name other than Kevin's, or recoverable credential appears anywhere in this report or its sources.

Dates. The rules-of-engagement record was signed 2026-09-20. The ten executed work packages ran between 2026-09-20 and 2026-09-21 (see section 4 for each run's exact start and end times). This report is dated 2026-09-23.

Authoriser. Kevin, in his role as the product's owner and Information Security Manager, is the sole authoriser, incident contact and stop authority named on the rules-of-engagement record (`docs/security/pentest-runs/roe-record.md`), signed 2026-09-20, quoted there verbatim: "I agree with the details in the pentest, and you can take this attestation as my signature."

Tester and reviewer roles. Testing was performed by this project's own AI agent sessions (Claude and Codex), never by Kevin personally for the work packages in this round. Each run's own manifest names its tester and records that independent review is pending, since WP12 (cross-model review) has not started.

Techniques and caps. Permitted tools, numeric caps (one manual request at a time, one harmless canary per class, one controlled cross-tenant object per class), and hard bans (no file reads outside the target application, no command execution against a target, no production entitlement change, no real money movement, no payment initiation, no bank-credential capture) are recorded in full in the rules-of-engagement record and were not exceeded in any run.

3. Methodology and standards

Testing followed `docs/security/PENTEST-METHODOLOGY.md`, a reconciliation of two independently produced draft methodologies (Claude's and Codex's) into one agreed test catalogue, evidence format and severity rubric (board item A43). It layers several standards, each scoped to the surface it actually fits, rather than claiming a single blanket certification against any one of them:

Standard	Applied to
OWASP ASVS 5.0.0 (Level 2 baseline, risk-selected Level 3 in named control families)	Requirements backbone across every surface
OWASP WSTG 4.2	The browser-delivered web shell and <code>/design</code> preview routes
OWASP API Security Top 10:2023	The REST API and the API-shaped parts of OAuth, MCP, and the Finexer/TrueLayer/Stripe boundaries
OWASP MASVS/MASTG 2.0.0	The Android app shell (static analysis only in this round)
OAuth 2.0 Security BCP, RFC 9700	The OAuth 2.1 authorisation server
The MCP specification (version <code>2025-06-18</code> , as declared by the server)	The MCP connector
OWASP Top 10 for LLM Applications 2025	Penny and the OpenRouter integration
FIRST CVSS 4.0	Optional technical-severity colour on a confirmed finding, never the severity gate itself
NIST SP 800-115	The rules-of-engagement, execution lifecycle, and the run-manifest/per-test-record/finding-record evidence structure this report draws on

This is an assessment mapped to selected ASVS requirements and WSTG/MASTG procedures. It is not, and must never be described as, "OWASP certified", "ASVS compliant", a complete ASVS verification, "CREST tested", or an independent or third-party engagement. Severity uses `SECURITY.md` section 3's four-band scale (Critical, High, Medium, Low), and the remediation-SLA targets in section 3a (reproduced in section 8 below).

4. Coverage matrix

One row per work package. Case counts and results are taken from each run's own manifest and per-case records under `docs/security/pentest-runs/<run-id>/`. Where a single case recorded a mixed outcome across sub-components (for example, one property held and another did not), the row below counts it once, by its recorded headline verdict; the finding register in section 5 and the underlying per-test record carry the full detail.

WP	Run id	Board item	Dates (UTC)	Cases	Pass	Fail	Blocked	N/A	Not run
WP1: Web shell and <code>/design</code> routes	A48-2026-09-20	A48	2026-09-20, 15:14-16:02Z	12	7	3	2	0	0
WP2: API inventory, credentials, rate limits, error handling, CORS	A49-2026-09-21	A49	2026-09-21, 05:47-06:05Z	7	3	4	0	0	0
WP3: API tenant and object authorisation, account deletion	A50-2026-09-20	A50	2026-09-20, 17:45-20:18Z	3	2	1	0	0	0
WP4: API input handling, uploads, business-logic ordering	A51-2026-09-20	A51	2026-09-20, 20:40-21:21Z	7	6	1	0	0	0
WP5: OAuth 2.1 authorisation server	A52-2026-09-20	A52	2026-09-20, 12:17-12:30Z	10	8	2	0	0	0
WP6: MCP connector	A53-2026-09-21	A53	2026-09-21, 05:49-05:55Z	11	8	2	0	1	0
WP7a: Android app shell, static analysis	A54-2026-09-20	A54	2026-09-20, 17:44-17:58Z	3	0	3	0	0	0
WP7b: Android app shell, dynamic (device/emulator)	none	A55	not run	0	0	0	0	0	all
WP8: iOS app shell	none	A56	not run	0	0	0	0	0	all
WP9: Finexer and TrueLayer boundary	A57-2026-09-20	A57	2026-09-20, 21:38-21:46Z	10	5	2	2	1	0
WP10: Stripe fail-closed boundary	A58-2026-09-21	A58	2026-09-21, 05:40-05:56Z	5	4	0	1	0	0
WP11: OpenRouter and Penny trust boundary	A59-2026-09-20	A59	2026-09-20, 18:20-18:45Z	8	6	2	0	0	0
WP12: Cross-model review	none	A60	not run	0	0	0	0	0	all
Total (WP1-WP11, executed)				76	49	20	5	2	0

WP3 note. The `A50-2026-09-20` run record contains a fourth section, `API-15`, attempt 1, marked VOID because it ran against the wrong identity (incident A78, tracked p1 on the board): it is excluded from the case count above, and the retained `API-15` result is the valid second attempt, run against genuine PT-C after the mandatory identity gate was corrected.

WP7a note. All three cases in WP7a (`AND-01`'s backup-flag sub-result, the static half of `AND-08`, and `MOB-01`) recorded Fail as their headline verdict, but each is a pre-documented, already-known gap (dated back to its original documentation commit, per the methodology's own "backdate the acknowledge clock" rule), re-confirmed live against the built artefact rather than newly discovered; `AND-01` and the static half of `AND-08` each also carry a Pass on a distinct sub-component within the same case (exported-component protection, and callback payload exposure, respectively). None of the three raised a fresh board item: `AND-01` and `AND-08` are pre-documented, accepted design gaps recorded in `PENTEST-METHODOLOGY.md` section 6.5.1 and remain open; `MOB-01` tracks to A77.

WP7b: not run. Rationale: dynamic Android testing (session-token storage inspection, biometric-lock reachability, deep-link race, WebView bridge exposure, TLS/cleartext behaviour under an intercepting proxy) needs a physical device or emulator with `adb`; neither is provisioned on this VPS, and `adb` / `mitmproxy` are not installed. Owner: Kevin, to provision a device or emulator, or defer to the external A7 engagement (board item A55).

WP8: not run. Rationale: full iOS dynamic testing needs a named TestFlight build, a dedicated iOS device, and a Mac for entitlement and `Info.plist` inspection; none of that is available to an agent session. Kevin has a TestFlight build and a device but has not yet run or assigned the dynamic cases. Owner: Kevin, to run this directly or defer it to the external A7 engagement (board item A56). Only the repository-level static review has been done for iOS so far, folded into WP7a's static coverage where the code is shared.

WP12: not run. Rationale: the cross-model review (a Codex session auditing every Claude-run work package's Fail evidence, and a Claude session auditing every Codex-run package) has not started. It is gated on WP1 through WP11 being complete or explicitly Blocked, which is now true, so this is the next work package to schedule, not a step skipped. Owner: Kevin, to coordinate the next Claude and Codex session pair (board item A60). Until WP12 completes, every severity in section 5 is single-reviewer and provisional.

Two further gaps recorded on the coverage side, not visible as a work package row above: `FIN-06` (webhook payload retention confirmation) and the accepted-delivery live halves of `FIN-01` and `TL-02` could not be completed within WP9, because this testing has no production database read path and no provider-approved sandbox consent exists; these are recorded Blocked within WP9's own tally above, not silently passed.

5. Findings register

Severity bands are `SECURITY.md` section 3's Critical / High / Medium / Low / Informational. "Status" reflects the board (`TOD0.md`) state as of 2026-09-23. "Production status" and "retest status" are stated per the rule established in section 1: nothing here is "remediated" or "closed" until it is on production and retested.

High

Id	Title	Affected surface	Status	Fix commit	Production status	Retest status
A82	Account deletion never revokes the Finexer consent first, orphaning it at the provider	<code>DELETE</code> account, retention/deletion path	Fixed on main	<code>2488763e</code>	Not deployed	Pending
A83	<code>GET /connections</code> does not list live Finexer connections, hiding the connection A82's disconnect-first step needs	Connections listing route	Fixed on main	<code>c35ac008</code>	Not deployed	Pending
A84	A deleted account's session token is not invalidated and remains usable for up to 7 days, including for writes that can reattach if the account is recreated with the same email	Session/auth lifecycle	Fixed on main	<code>40fed391</code>	Not deployed	Pending
A91	MCP output masking is structural only and never sanitises kept field content; an instruction-shaped merchant/category/insight string reaches the connecting assistant unmodified (prompt-injection surface)	MCP connector output masking	Fixed on main	<code>9c5b7ef9</code>	Not deployed; connector itself is off in production (A17), so not exploitable there today	Pending

A82. WP3's live account-deletion case (`API-15` , run `A50-2026-09-20`) found that `erase_user` deletes every local trace of an account but never calls a bank-connection disconnect first; the upstream Finexer consent is left live and orphaned. The fix inserts a disconnect-before-delete step ahead of the existing local erase, so the provider-side consent is revoked as part of account deletion rather than left dangling. Verified so far by the regression tests added alongside the fix commit; the retest will re-run the disconnect-then-delete procedure live against a fresh disposable identity, on production, once released, and confirm the upstream consent no longer exists afterwards.

A83. The same run found that `GET /connections` only lists TrueLayer connections, never Finexer ones, which meant a caller (including the account-deletion flow A82 needed to fix) had no reliable way to discover a live Finexer connection to disconnect. The fix adds Finexer connections to that listing. Verified so far by the regression tests added with the fix. The retest will confirm a live Finexer connection appears correctly in the listing on production.

A84. The same run's token-invalidation half found that a deleted account's bearer session token kept authenticating reads and writes for up to seven days after deletion, and that a write against a deleted account's identifiers could reattach if the account was later recreated with the same email. The fix invalidates the session token as part of account deletion. Verified so far by the regression tests added with the fix. The retest will replay a pre-deletion token against a live production deletion and confirm it is rejected immediately, not merely eventually.

A91. WP6's `MCP-06` case found that `app/services/mcp_mask.py` drops fields by shape only and never inspects or sanitises the content of the fields it keeps, so an instruction-shaped string placed in a merchant name, recurring-series description, or insight trigger (all provider-supplied text a user does not fully control) would reach a connected external assistant unmodified: a live prompt-injection surface with no content-level mitigation. The fix adds content-level sanitisation to the masking layer. Verified so far by the regression test added with the fix, run against the affected code path directly. The connector is off in production by design (`MCP_CONNECTOR_ENABLED` unset, board item A17), confirmed live 2026-09-23 (an anonymous `initialize` request returns 401 with no `WWW-Authenticate` challenge on both the Vercel-fronted path and the direct Railway host, unlike UAT, which advertises the challenge), so this finding has no production attack surface today; it does have one on UAT, where the connector is enabled. It must be fixed and retested before the connector is enabled in production, which is separately gated on Finexer's written design sign-off (board item F1, still open). The retest will re-run `MCP-06` 's injection canaries against UAT once F1's design is agreed and, if the connector is then enabled in production, against production too before that switch is treated as complete.

Medium

Id	Title	Status	Fix commit	Production status	Retest status
A73	OAuth consent page under-emphasises the true redirect host relative to the connector's self-reported name	Open	none	N/A	Pending
A74	Refresh-token rotation does not cascade-revoke the sibling access token from the same grant	Fixed on main	<code>eac94538</code>	Not deployed	Pending
A79	Bank narrative text sent to OpenRouter for categorisation and Penny read tools, unredacted	Open	none	N/A	Pending
A88	Finexer consent callback accepted a missing <code>state</code> parameter	Fixed on main	<code>683078c8</code>	Not deployed	Pending
A89	Webhook path-secret comparison was not constant-time	Fixed on main	<code>f4983f8e</code>	Not deployed	Pending
A92	Production's proxy chain did not strip a caller-supplied <code>X-Real-IP</code> / <code>X-Forwarded-For</code> header, so IP-keyed rate limits were bypassable	Fixed on main	<code>d5fbdfe1</code>	Not deployed; production release additionally gated on A110 (trusted-proxy hop handling), in progress	Pending
A95	<code>GET /logo/{domain}</code> carried no rate limit at all	Fixed on main	<code>aeadb348</code>	Not deployed	Pending

Low

Id	Title	Status	Fix commit	Production status	Retest status
A76	<code>/design/*</code> preview routes were publicly indexable, no <code>robots.txt</code> / <code>X-Robots-Tag</code>	Fixed on main	<code>e7621167</code>	Not deployed	Pending
A77	Native-purchase <code>X-Client-Platform</code> header check can be bypassed by omitting it (billing not live)	Open	none	N/A	Pending
A80	No global/service-wide OpenRouter spend ceiling, only a per-user monthly allowance	Fixed on main	<code>7bea0094</code>	Not deployed	Pending
A81	Per-user LLM allowance check fails open, not closed, on an internal lookup error (documented, deliberate trade-off)	Open	none	N/A	Pending
A85	<code>PATCH /preferences</code> had no optimistic-concurrency check and accepted an unadvertised field (mass assignment)	Fixed on main	<code>4b866395</code>	Not deployed	Pending
A86	Commitment state machine allowed out-of-order transitions, no create-time idempotency check	Fixed on main	<code>1f8a318d</code>	Not deployed	Pending
A90	MCP <code>initialize</code> handler never validated or negotiated the client's requested protocol version	Fixed on main	<code>141b057c</code>	Not deployed	Pending
A93	Unhandled NUL byte in a search query parameter crashed one endpoint with a 500 (no data leaked)	Fixed on main	<code>f73638e6</code>	Not deployed	Pending

Informational

Id	Title	Status	Fix commit	Production status	Retest status
A94	Dead, unreachable authorisation branch in <code>current_user</code> for an out-of-scope bot credential; access is still correctly denied elsewhere, not itself a weakness	Open	none	N/A	N/A, not a weakness

Residual follow-up disclosed alongside these findings

Id	Title	Status	Fix commit	Production status	Retest status
A106	Finexer consent revoke failure during a Finexer outage is swallowed and the local consent doc is deleted anyway, orphaning the consent with no record to retry from	Open	none	N/A	Pending

A106 is not itself one of this round's pentest findings; it is a follow-up gap identified in A82's own fix (the disconnect-then-delete ordering A82 introduced still has no retry path if the remote revoke call fails partway through, for example during a Finexer outage). It is disclosed here because it sits directly on the same account-deletion lifecycle as A82, A83 and A84 and is still open.

6. Blocker and limitation register

Blocker or limitation	Detail	Status
FIN-06 (webhook payload retention/TTL)	No production database or admin-API read path exists for this testing session to confirm live payload retention behaviour	Blocked, unresolved; owner Kevin (provide a scoped read path or defer to A7)
FIN-01 and TL-02 , accepted-delivery live halves	No Finexer-approved sandbox or test consent exists, and no TrueLayer-equivalent sandbox/test connection exists, to safely drive a live accepted-delivery webhook	Blocked, unresolved; owner Kevin (obtain a provider sandbox, or accept as deferred to A7)
OPEN_SIGNUP window on production (2026-09-19)	A roughly 36-minute window during which production's normal Google/Apple-identity allow-list gate was relaxed to create PT-A and PT-B, then closed (board item A63). The post-window check for unexpected registrations during that window was deliberately not run: this session's own permission boundary declined the read, and Kevin judged it unnecessary at the time given the gate admitted only a verified Google or Apple identity throughout, never anonymous registration	Not retrospectively checked; available to Kevin if he wants the count run later
Device testing (WP7b, WP8)	No Android device/emulator or adb on this VPS; no iOS device, TestFlight assignment, or Mac available to an agent session	Not run; see section 4
Cross-model review (WP12)	Not started; every severity in this report is single-reviewer, provisional pending WP12 and Kevin's sign-off	Not run; see section 4
TrueLayer live cases (TL-01 , TL-03 , TL-05 , and TL-04 's live-write half)	Deferred, not exercised against production, because TrueLayer is being removed from production (board item A67); their result is recorded as deferred/UAT-only rather than Pass or Fail	Deferred by design, not a gap in this round's execution

7. MCP connector production status

The MCP connector is disabled in production by design: the `MCP_CONNECTOR_ENABLED` environment variable is unset on the production Railway service, so `backend/app/main.py`'s `_routers()` never registers the OAuth authorisation-server routes or the MCP connector routes there at all (board item A17). This was re-confirmed live on 2026-09-23: an anonymous `initialize` request to the connector returns 401 with no `WWW-Authenticate` challenge header, on both the Vercel-fronted path (`https://wealth.auriqltd.co.uk`) and the direct Railway host, whereas the equivalent request against UAT (`https://uat.wealth.auriqltd.co.uk`, where the connector is enabled) does advertise the challenge. This absence of a challenge header on production is the decisive signal that the connector is genuinely unregistered there, not merely returning a generic authentication failure for a route that exists.

Both cases that specifically test this absence, `OAuth-01` and `MCP-01` , Passed (section 4, WP5 and WP6). Every other OAuth and MCP case in this round (`OAuth-02` through `OAuth-10` , `MCP-02` through `MCP-11`) ran on UAT only, because there is no route on production for them to reach. A91, the one High finding against the MCP connector, is consequently not exploitable on production today; it is a live, UAT-only exposure until the connector is enabled there. Enabling the connector in production is gated on Finexer's written design sign-off (board item F1, open); that gate is independent of, and does not substitute for, fixing and retesting A91 itself first.

8. Remediation SLA and timeline

Remediation targets are `SECURITY.md` section 3a's bands, reproduced here for this report's own findings:

Severity	Acknowledge	Remediate or mitigate
Critical (P1)	Within 24 hours	Within 72 hours (a temporary mitigation counts, if the exposure genuinely stops)
High (P2)	Within 3 business days	Within 14 days
Medium (P3)	Within 5 business days	Within 30 days, or the next scheduled dependency/release cycle if sooner
Low (P4)	Best effort	Best effort, tracked on <code>TODO.md</code> , not silently dropped

All four High findings (A82, A83, A84, A91) were acknowledged the same day they were found (2026-09-20/21) and fixed on `main` by 2026-09-22, comfortably inside the 14-day remediate target measured from acknowledgement. That target is about a fix existing and merged; it is not itself satisfied by deployment or retest, which this report tracks separately as "Pending" throughout, per the "fixed on main, not remediated" wording rule stated in section 1.

What happens next, in order:

1. **A110** (trusted-proxy hop handling), in progress as of this report's date, resolves the two-ingress-path ambiguity (Vercel-fronted web traffic versus the mobile apps' direct Railway calls) that blocks releasing A92's rate-limit fix safely to production.
2. **Production release**, once A110 lands, carries A82, A83, A84, A91, and every other fixed finding listed in section 5 to production via `scripts/release.py` .
3. **Retest**, against the released production build, confirms each finding's fix live rather than relying on the regression tests alone; see each High finding's own paragraph in section 5 for what its retest specifically checks.
4. **WP12** (cross-model review) runs once WP1 through WP11 are complete or explicitly Blocked, which is now true; it validates or dismisses every Fail recorded in this round with a written reason from the opposite model, and records each retested finding as Fixed, Partially fixed, Not fixed, or Not retestable.
5. **Final report v1.0** is produced once the retest and WP12 both complete, replacing this draft, and folds into `SECURITY.md` section 3b and the Finexer compliance questionnaire's Q11 answer.

Remediation start for the Medium/Low findings still open (A73, A77, A79, A81, A94, and the residual A106) begins 1 October 2026, per their own board priority and the section 3a cadence above; none of them is a High or Critical severity, so none blocks the release sequence above.

9. Independent testing

This is internal testing, performed by this project's own AI agent sessions under a Kevin-signed rules-of-engagement record, not an independent third-party or CREST engagement. The separate external engagement, a CREST-accredited penetration test (board item A7), remains open and is booked by Kevin ahead of public launch. This report, and the internal testing programme it describes, is that engagement's internal precursor: it narrows what the external testers need to spend time on and gives Finexer earlier visibility, but it does not replace, and must never be cited as equivalent to, the external CREST engagement.

10. Sign-off and revision history

Sign-off (this draft). The underlying internal testing programme (SECURITY.md section 3b) was signed off by Kevin, 2026-09-21, given as a written attestation in a working session with Claude ("Happy to sign this"), not a handwritten or cryptographic signature. This report itself, as a document, has not separately been signed by Kevin as of its 2026-09-23 draft date; that sign-off is expected alongside or after review of this draft, ahead of it being shared with Finexer.

Revision history.

Version	Date	Change
v0.1 (DRAFT)	2026-09-23	First draft, produced for Finexer ahead of production release, retest and WP12; covers the 10 of 12 work packages executed 2026-09-20 to 2026-09-21
v1.0 (planned)	after A110, production release, retest and WP12 complete	Final report: replaces every "Pending" retest status above with a recorded outcome, folds WP12's cross-model sign-off into the coverage matrix and findings, and supersedes this draft as the input to SECURITY.md section 3b and Finexer Q11